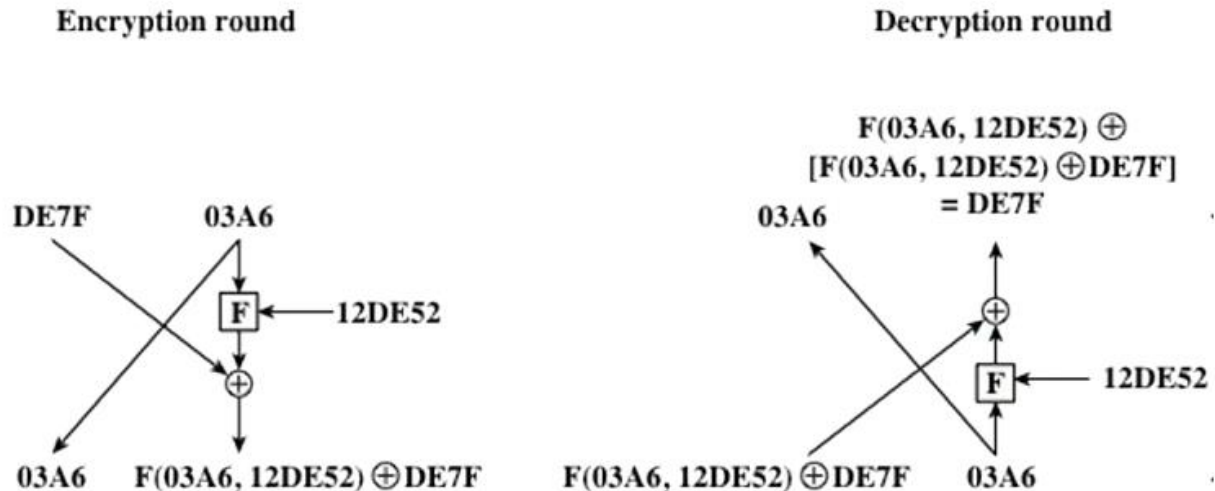


CSC432 – Information Security

Solution

Q# 01



Q# 02

AES does not split the input into two halves.

Q# 03

SubBytes

Each individual byte of State is mapped into a new byte in the following way: The leftmost 4 bits of the byte are used as a row value and the rightmost 4 bits are used as a column value. These row and column values serve as indexes into the S-box to select a unique 8-bit output value.

ShiftRows

The first row of State is not altered. For the second row, a 1-byte circular left shift is performed. For the third row, a 2-byte circular left shift is performed. For the third row, a 3-byte circular left shift is performed.

MixColumns

MixColumns operates on each column individually. Each byte of a column is mapped into a new value that is a function of all four bytes in that column.

AddRoundKey

The 128 bits of State are bitwise XORed with the 128 bits of the round key.

Q# 04

1. It is computationally easy for a party B to generate a pair (public key PUB, private key PRb).
2. It is computationally easy for a sender A, knowing the public key and the message to be encrypted, M, to generate the corresponding ciphertext:

$$C = E(\text{PUB}, M)$$

3. It is computationally easy for the receiver B to decrypt the resulting ciphertext using the private key to recover the original message:

$$M = D(\text{PRb}, C) = D(\text{PRb}, E(\text{PUB}, M))$$

4. It is computationally infeasible for an opponent, knowing the public key, PUB, to determine the private key, PRb.
5. It is computationally infeasible for an opponent, knowing the public key, PUB, and a ciphertext, C, to recover the original message, M.

Q# 05

1, 8839, 8849, 78216311

Q# 06

Constant exponentiation time

Ensure that all exponentiations take the same amount of time before returning a result; this is a simple fix but does degrade performance.

Random delay

Better performance could be achieved by adding a random delay to the exponentiation algorithm to confuse the timing attack

Blinding

Multiply the ciphertext by a random number before performing exponentiation; this process prevents the attacker from knowing what ciphertext bits are being processed inside the computer and therefore prevents the bit-by-bit analysis essential to the timing attack.

Q# 07

[$2316 \bmod 23 \times 234 \bmod 23 \times 232 \bmod 23 \times 23 \bmod 23$] $\bmod 23$

Q# 08

Conventional Encryption	Public-Key Encryption
<i>Needed to Work:</i> 1. The same algorithm with the same key is used for encryption and decryption. 2. The sender and receiver must share the algorithm and the key. <i>Needed for Security:</i> 1. The key must be kept secret. 2. It must be impossible or at least impractical to decipher a message if the key is kept secret. 3. Knowledge of the algorithm plus samples of ciphertext must be insufficient to determine the key.	<i>Needed to Work:</i> 1. One algorithm is used for encryption and a related algorithm for decryption with a pair of keys, one for encryption and one for decryption. 2. The sender and receiver must each have one of the matched pair of keys (not the same one). <i>Needed for Security:</i> 1. One of the two keys must be kept secret. 2. It must be impossible or at least impractical to decipher a message if one of the keys is kept secret. 3. Knowledge of the algorithm plus one of the keys plus samples of ciphertext must be insufficient to determine the other key.

Q# 09

Time

Q# 10

Confidentiality of data

Q# 11

Integrity of data

Q# 12

Availability of service

Q# 13

Confidentiality of service

Q# 14

Launches

Q# 15

No one

Q# 16

One key for symmetric and two keys for asymmetric

Q# 17

Cyptanalysis and brute force

Q# 18

- (1) The cost of breaking the cipher exceeds the value of the encrypted information
- (2) The time required to break the cipher exceeds the useful lifetime of the information.

Q# 19

1. There is the practical problem of making large quantities of random keys. Any heavily used system might require millions of random characters on a regular basis. Supplying truly random characters in this volume is a significant task.

2. Even more daunting is the problem of key distribution and protection. For every message to be sent, a key of equal length is needed by both sender and receiver. Thus, a mammoth key distribution problem exists.

Q# 20

L	A	R	G	E
S	T	B	C	D
F	H	I/J	K	M
N	O	P	Q	U
V	W	X	Y	Z

Q# 21

O	C	U	R	E
N	A	B	D	F
G	H	I/J	K	L
M	P	Q	S	T
V	W	X	Y	Z

Q# 22

UZTBDLGZPNNWLGTGTUEROVLDBDUHFPERHWQSRZ

Q# 23

25! Or 2^{84}

Q# 24

24!

Q# 25

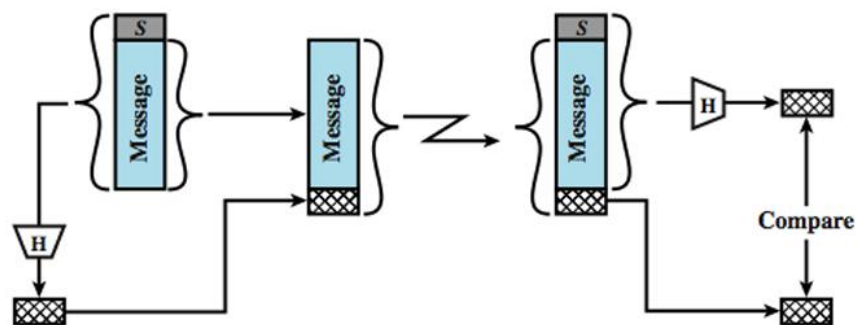
If password hashes get leaked, it takes more time to brute-force longer passwords as compared to shorter ones. Longer passwords are harder to guess and/or shoulder surf.

Q# 26

Party A -> $8^3 \bmod 33$

Party B -> $8^2 \bmod 33$

Q# 27



Q# 28

If complete mediation is enforced 100%, it will greatly reduce the system performance and poorly impact the user experience because every single access to the system will be guarded with security checks.

Q# 29

Because every sample looks different, it would be a polymorphic virus (which uses a different encryption routine on each infection), or metamorphic virus (which changes virus body upon each infection). Anti-virus can detect it statically by looking for malware-like code (such as decryption routines) or dynamically by its behavior monitoring (malware-like actions such as modifying too many files and copying itself to

usb drives etc.). Anti-virus can NOT use simple techniques like checking file size or file hash, these methods won't catch the malware.

Q# 30

Company should get their public key certified by a CA that is trusted by clients. Clients can then inspect the certificate and be confident that the key does not belong to an attacker.

Q# 31

Open ended. 3 marks for (scenario specific) threats, one against confidentiality, second against availability
3 marks for solution of those threats

Q# 32

- a) Careful hiring by initial screening and investigation, Employee training, Signing policy agreements, Updating control on termination of employment
- b) Restricted access to physical assets, Multi-layer authentication, Access Control List, Monitoring through Camera Keeping logs and records of access

Q# 33

- a) The best option is to do Record level encryption that provides better control on individual records and is less complex as compared to field level encryption. Moreover separate keys can be used for each user if data is for individual users. Even in case of shared data we can make multiple copies encrypted with each user but this will consume extra space!
- b) **Symmetric Encryption:**
All records can be encrypted using either a single private key or creating a separate key for each user. The first option is convenient in terms of management but we can not hide that from different users. The other case is more secure but it will require high cost to manage a large number of private keys and it will keep growing with addition of new users.
Asymmetric Encryption:
In case of Asymmetric encryption Server would have to keep the public keys of all users and it will require specific procedures to do encryption with the public key of intended user who can later access it using its private key. It provides fool proof security as only the intended user can access its records however in case of share data, multiple copies needs to be stored.
- c) As explained in the last part, Server will encrypt each record with the public key of the intended user and then each one of them can access those records using private key!

Q# 34

1. Violation of Open Design because proprietary protocols can not be subject to public scrutiny by experts.
2. Separation of Privileges is being followed, as multiple security conditions are being checked.

3. Complete Mediation is being followed because initially the program had permissions. After some time the permissions were revoked. The operating system did not rely one-time check, instead it applied security checks on each access. Alternate answer: Principle of least-privilege is followed because the program was given a temporary privilege escalation, which was taken back after some time.

Q# 35

$$16^7 \bmod 187 = 135$$

$$24^7 \bmod 187 = 29$$

Q# 36

- a) RSA by itself is vulnerable to MITM attacks because attacker can share their own public key with both parties without either of them realizing. Alternate Answer: It is not vulnerable as in this mechanism the public key will be certified by the Certification Authority
- b) Hash function alone is not sufficient. MAC computation also requires a secret key as input, such as a pre-shared key or the private key of the sender.

Q# 37

Vendor will have to create and attach MAC to in order to prove the integrity and authenticity of the downloaded image. Vendor signs the MAC with their private key. User downloads the image and verifies the MAC with vendor's public key.

Q# 38

- a) social engineering, or more specifically phishing
people get panic by such threats and make decisions in haste
- b) phishing attack bcoz it was a look-alike web page operated by attacker
most people do not understand the meaning of SSL warnings, and want to finish their intended task asap.
- c) This computer has become a zombie, and is participating in a DDoS attack. Attackers infected the computer with a bot malware.
People fall for this attack due to not having good anti malware software, and downloading software from dangerous sources like torrents or piracy sites.

Q# 39

- a) principle of least privilege. Minimize the chances of access misuse.
- b) economy of mechanism, since a single layer is enough. Do not needlessly complicate the system.

Q# 40

$p = 7, q = 11$

$n = 77$

$\phi = 60$

given $e = 7$

Solving $7 \times d \bmod \phi = 1$, we get smallest $d = 43$

Public key = 7, 77

Private key = 43, 77

Encryption of message, say 5

$5^7 \bmod 77 = 47$

Decryption

$47^{43} \bmod 77 = 5$

Q# 41

Alice computes $A = 11^9 \bmod 47 = 38$

Bob computes $B = 11^{16} \bmod 47 = 3$ (hard to get it via calculator)

After sharing public keys, Alice computes shared key as $K = 3^9 \bmod 47 = 37$

Bob gets $K = 38^{16} \bmod 47 = 37$

Q# 42

Plaintext: v o t e f o r m e

Key: 2 4 5 2 4 5 2 4 5

Ciphertext: x s y g j t t q j

Q# 43

- It involves extra cost for sensor hardware.
- Biometric data is never exactly matched, instead a scoring system is used. As a result, false acceptances and false rejections happen in some cases.
- All biological characteristics are variable (due to wound, aging, emotion etc.). Hence biometric verification will fail in such cases.
- It makes anonymous access impossible.

Q# 44

Run time defenses should be applied, like non executable address space, address space randomization, guard pages etc. (Briefly explain all three). Compile time defenses are not an option since source code is not available.

Q# 45

Physical attacks:

Sleep deprivation: Preventing a node from going to idle sleep mode so that its battery is quickly drained. Node tampering: Physically modifying the node hardware, e.g. to disable communication, to input fake sensor data etc.

Network attacks:

Traffic analysis: Recording and analyzing the wirelessly transmitted packets.

Sinkhole attack: Malicious routing node advertising incorrect routes and attracting all traffic to itself.

Q# 46

A firewall that allows or drops the packets according to on pre-defined rules of checking layer 3 and layer 4 headers. Pros: It is fast and simple in operation. Transparent to end users. Cons: Can't protect against IP spoofing attacks, can't analyze packet contents to see if they are malicious etc.

Q# 47

1st query will be slower because the filter Assignment < 50 cannot be applied on encrypted fields. Whole Marks table (or at the very least, the complete Assignment column) should be downloaded and decrypted at the client side before filtering out correct rows.

2nd query can be quickly executed by encrypting the params 254 and CSC432 at the client side, and then running the query on server-side encrypted database, that will easily match the single row containing encrypted values of 254 and CSC432. [Note: only the client has got encryption/decryption keys, not the server.

Q# 48

Adding noise to the results of a database query. It is applied on statistical databases as a protection against inference attacks.

Some types

Data perturbation: swapping data between rows

Random sample query: run the query on a selected subset of rows.

Statistic adjustment: Adjust the statistical answers up or down by a small amount.

Q# 49

Incorrect statement.

Salt itself is not a secret information. Server stores hashcode = hash(password|salt).

If salt is leaked, attacker still needs to "crack" the hashcode to get the password.

Main benefit of salt is to slow down the dictionary attacks.

Q# 50

The Origin header is added automatically by browser to indicate the source of requests.

In CSRF attack, forged requests are initiated from attacker's website, hence the Origin header will disclose this information to server, which can then reject such requests.

Q# 51

Retro virus tries to bypass or hinder the operation of an antivirus, personal firewall, or other security programs.

They generally have a database of identification mechanisms for different security controls like process names, registry keys. Once identified, the security controls can be terminated or corrupted.

These could also block users from updating their antivirus software or opening of system utilities or antivirus vendor websites.

Q# 52

TRUMP WILL RELOCATE TO KASUR

T			P			L			E			A			T			A			-				N						
	R		M		-		I		L		R		L		C		T		-		O		K		S		R		S		O
		U				W				-				O			E			-					U				O		

Q# 53

1. 3233
2. 3120
3. 2753

Q# 54

Alice public = $6^5 \bmod 11 = 10$

Mallory public = $6^4 \bmod 11 = 9$

Bob public = $6^8 \bmod 11 = 4$

Key between Alice and Mallory

Alice calculates $K_1 = 9^5 \bmod 11 = 1$

Mallory calculates $K_1 = 10^4 \bmod 11 = 1$

Key between Bob and Mallory

Bob calculates $K_2 = 9^8 \bmod 11 = 3$

Mallory calculates $K_2 = 4^4 \bmod 11 = 3$

Q# 55

It is not a good idea because another message can be appended to the original message. This attack is termed as length extension attack where the attacker is able to append a message along with the original message.

So the resulting hash would look something like this: $h = H(k \parallel \text{message} \parallel \text{message}')$.

This way the hash would also be verified on the receiver's end. To solve this problem, HMAC should be used or a key must be added at both ends of the message for hashing.

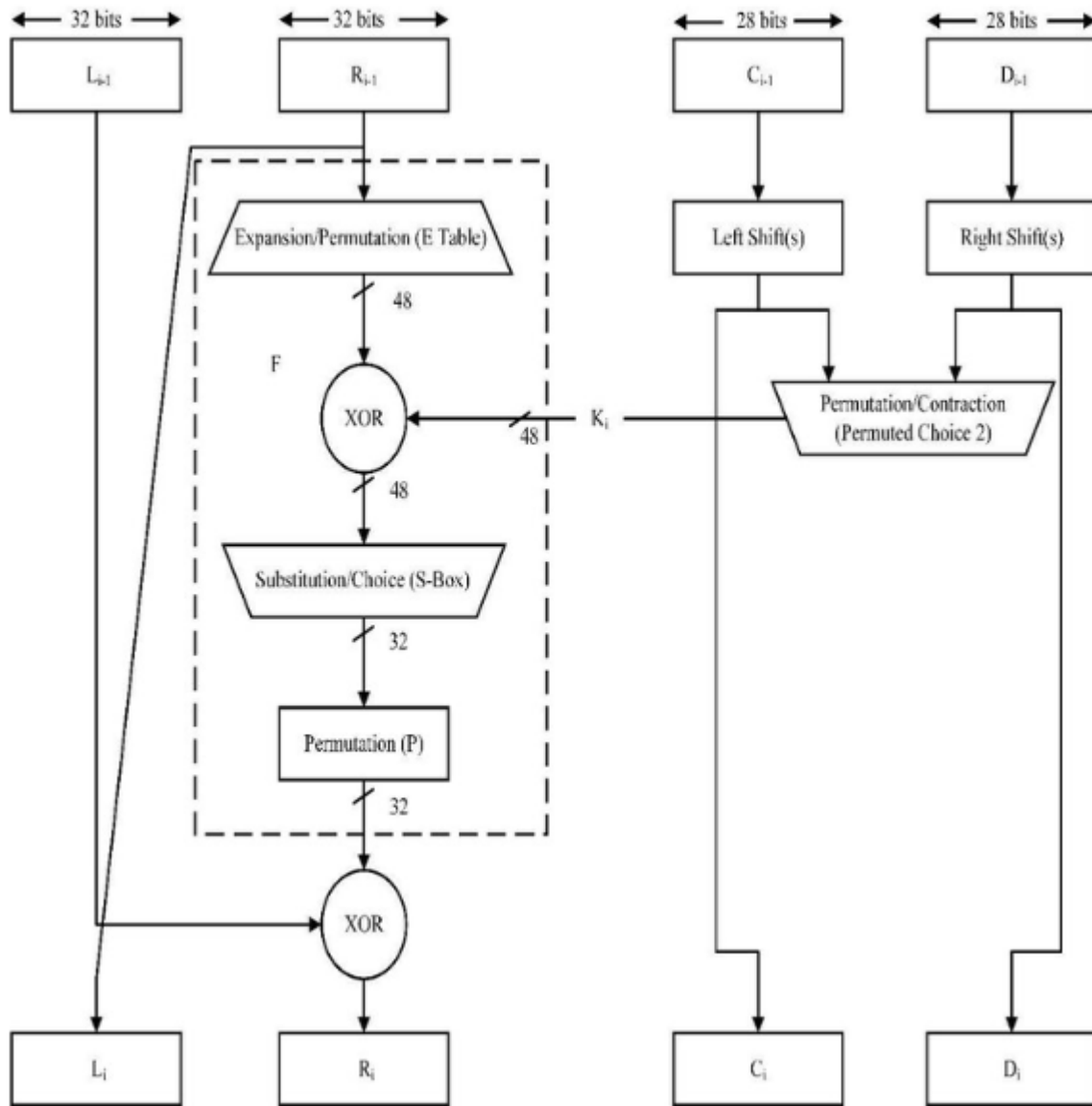
Q# 56

Those are intermediate certificates. The certificates are sent by server to allow the client to complete the trust chain so it can eventually reach the trust anchor.

Q# 57

No, the network would not be disabled because the Certification Authority can only sign or revoke a certificate. CA has nothing to do with the network.

Q# 58



Q# 59

1. Worm, auto spreading over the network devices by exploiting vulnerabilities in OS/apps.
2. Trojan, hidden functionality
3. Scareware + trojan, tempting user to install it.

Q# 60

1. Bob isn't authenticating alice at all. It's a one way authentication.

2. Using the master key. Because master key size is larger and its fixed. It is a standard secure key over which both parties agree after it is derived from pre-master key, random numbers of alice and bob.
3. Record protocol. 1. Application data 2. Change cipher spec protocol 3. Alert protocol 4. Handshake protocol
4. 2 keys in SSL v2.
One in each direction. One for integrity one of encryption.
6 keys in v3. One for integrity, as IV, and one for encryption from each side.
In both versions its derived from master keys.

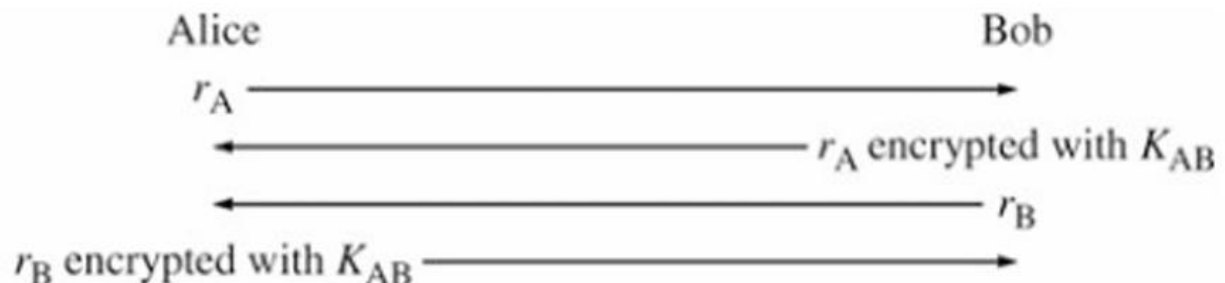
Q# 61

1. OFB (output feedback)
2. Synchronous stream cipher: key-stream (one-time pad) depends on the IV and the key
3. 1-bit error in transmission affects only one bit of plain tex
4. Yes, because if you get the OTP, you can decrypt any group of messages
5. In this case, only the first group of message will be decrypted since the attacker knows the first IV. For the second group, the IV will change, therefore the attacker will not be able to decrypt the message.

Q# 62

Because checksums even if computed with a secret code, can be easily broken. They are extremely vulnerable and the chances of collision are also high as the total number of bits are usually between 16 bits. Also, checksums can be easily forged and the secret code can be extracted from them.

Q# 63



Q# 64

It is because hashing used to compute a MAC algorithm is much faster. At the same time, MAC using encryption can be decrypted back. Since hashing is irreversible, it is a safe MAC computation method.

Q# 65

1. MAC computation via hashing or even encryption
2. Digital signature

The difference is digital signature proves non-repudiation as well. The common things are both ensures data integrity and authenticity.

Q# 66

- Alice can digitally sign data and then send it to Bob with the secret key (symmetric) already exchanged with them.
- Alice can first digitally sign the data and then encrypt it with the public key of Bob so only bob can decrypt the data.
- In both the above cases the following properties are achieved:
 - Confidentiality
 - Integrity
 - Non-repudiation

Q# 67

1. Given a hash value, say 5, any number that sums up to 5, 15, 25, ... will be a valid preimage

14 (sum = 5), 429 (sum = 15), 22876 (sum = 25)

Since it is quite easy to find preimages, the requirement is not met.

2. It is trivial to find different numbers that hash to same value, e.g.
 $H(247) = 13 \bmod 10 = 3$, $H(21) = 3 \bmod 10 = 3$

Q# 68

Reason	Outcome of non-revocation
Client's private key compromised	Attacker can pretend to be the client
Staff member on leave, or left the company	Staff member can still represent the company
Subject details changed	Certificate will be no longer useful for subject
CA's private key compromised	Attacker can issue fake certificates to themselves
Subject provided false information	Users will keep on trusting deceptive subject

Q# 70

Heavy traffic load on the Internet bcoz every client needs to download it regularly

CRLs become outdated very quickly and do not hold information of most recently revoked certificates.

Q# 71